

# Cloud Security Quick Scan Report

Technical assessment mapped to ISO/IEC 27001:2022 Annex A

## Noordkust Logistics NV

Scan date: 04 October 2026

Report generated: 04 October 2026

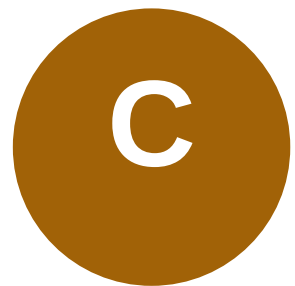
Scope:

 Noordkust Microsoft 365

 Noordkust Azure

 AWS production

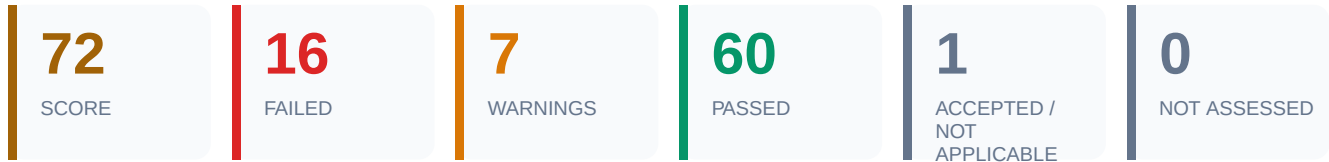
 GitHub organisation



Score 72/100

# Executive summary

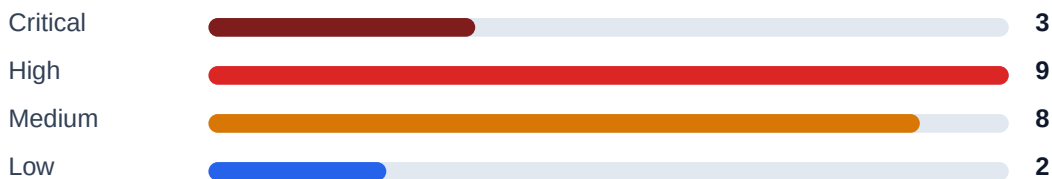
Noordkust Logistics NV was assessed with automated, read-only checks across 4 system(s). 84 of 84 checks could be assessed. Overall grade C (72/100). 16 failed checks and 7 warnings, of which 3 critical and 9 high severity. Biggest gaps: Privileged Access, Governance & Hygiene. 1 finding is risk accepted.



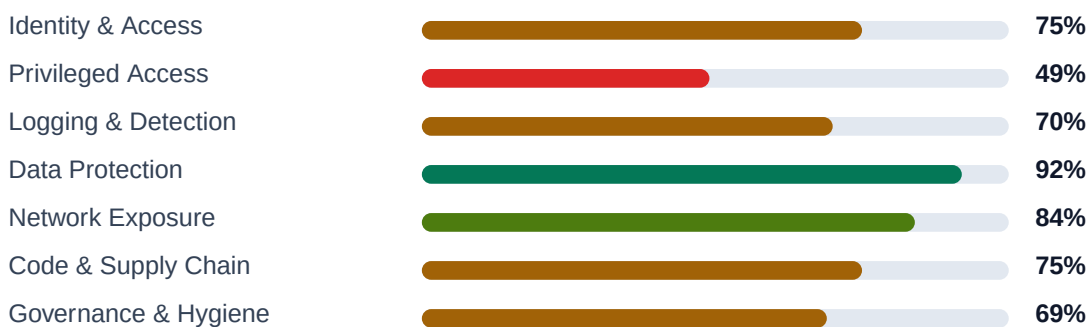
## Results per system

| System                  | Identity                         | Grade  | Failed | Warnings |
|-------------------------|----------------------------------|--------|--------|----------|
| Noordkust Microsoft 365 | Tenant Noordkust Logistics NV... | C (72) | 3      | 5        |
| Noordkust Azure         | Tenant...                        | B (87) | 1      | 1        |
| AWS production          | AWS account 111122223333         | C (65) | 8      | 0        |
| GitHub organisation     | github.com/noordkust-demo        | C (74) | 4      | 1        |

## Findings by severity



## Score by security domain



## Compared to the previous scan

Previous scan on 20 September 2026 scored 54 (grade D); now 72 (grade C). 21 issue(s) resolved, 0 new, 24 persisting.

# ISO/IEC 27001:2022 Annex A assessment

Each automated check is mapped to the Annex A control it provides evidence for (primary) and related controls (secondary). Verdicts cover only the aspects of a control that can be verified automatically in the cloud configuration; organisational aspects (policies, procedures, awareness) are outside the scope of an automated scan.

Evidence strength says how much the checks say about a control. Strong: at least one high or critical check, or at least two checks, map to the control as their primary control. Limited: only low, medium or informational primary checks. Indirect: only checks that map to the control as a secondary control. A control is only rated Effective with strong evidence; a clean result with limited or indirect evidence is reported as "No issues found (limited evidence)". Accepted risks still count as gaps in the control verdict.

26 of 38 assessable Annex A controls evidenced by this scan; the others are listed in the appendix as not covered by automated checks.

3 EFFECTIVE

9 NO ISSUES FOUND (LIMITED EVIDENCE)

8 PARTIALLY EFFECTIVE

8 NOT EFFECTIVE

0 NOT ASSESSED

| Control | Title                                                                                               | Verdict             | Evidence | Score |
|---------|-----------------------------------------------------------------------------------------------------|---------------------|----------|-------|
| A.5.14  | Information transfer                                                                                | No issues, limited  | Limited  | 100%  |
| A.5.15  | Access control<br>Issues on: Noordkust Microsoft 365, GitHub organisation                           | Partially effective | Strong   | 73%   |
| A.5.16  | Identity management                                                                                 | No issues, limited  | Indirect | 100%  |
| A.5.17  | Authentication information<br>Issues on: AWS production, Noordkust Microsoft 365                    | Partially effective | Strong   | 71%   |
| A.5.18  | Access rights<br>Issues on: Noordkust Microsoft 365                                                 | Partially effective | Strong   | 81%   |
| A.5.19  | Information security in supplier relationships                                                      | No issues, limited  | Limited  | 100%  |
| A.5.21  | Managing information security in the ICT...<br>Issues on: GitHub organisation                       | Partially effective | Strong   | 67%   |
| A.5.23  | Information security for use of cloud services                                                      | No issues, limited  | Indirect | 100%  |
| A.5.24  | Incident management planning and...                                                                 | No issues, limited  | Limited  | 100%  |
| A.5.25  | Assessment and decision on information...                                                           | No issues, limited  | Indirect | 100%  |
| A.6.7   | Remote working                                                                                      | No issues, limited  | Indirect | 100%  |
| A.8.1   | User endpoint devices                                                                               | No issues, limited  | Limited  | 100%  |
| A.8.2   | Privileged access rights<br>Issues on: AWS production, Noordkust Microsoft 365, GitHub organisation | Not effective       | Strong   | 48%   |
| A.8.3   | Information access restriction<br>Issues on: Noordkust Microsoft 365                                | Partially effective | Strong   | 99%   |
| A.8.4   | Access to source code<br>Issues on: GitHub organisation                                             | Not effective       | Strong   | 63%   |
| A.8.5   | Secure authentication<br>Issues on: AWS production, Noordkust Microsoft 365                         | Not effective       | Strong   | 68%   |
| A.8.8   | Management of technical vulnerabilities<br>Issues on: GitHub organisation, AWS production           | Not effective       | Strong   | 47%   |

| Control | Title                                                                          | Verdict             | Evidence | Score                       |
|---------|--------------------------------------------------------------------------------|---------------------|----------|-----------------------------|
| A.8.9   | Configuration management<br>Issues on: Noordkust Microsoft 365, AWS production | Not effective       | Strong   | <div><div></div></div> 42%  |
| A.8.12  | Data leakage prevention<br>Issues on: GitHub organisation                      | Partially effective | Strong   | <div><div></div></div> 97%  |
| A.8.13  | Information backup<br>Issues on: Noordkust Azure                               | Partially effective | Strong   | <div><div></div></div> 83%  |
| A.8.15  | Logging                                                                        | Effective           | Strong   | <div><div></div></div> 100% |
| A.8.16  | Monitoring activities<br>Issues on: Noordkust Azure                            | Not effective       | Strong   | <div><div></div></div> 67%  |
| A.8.20  | Networks security<br>Issues on: AWS production                                 | Not effective       | Strong   | <div><div></div></div> 82%  |
| A.8.21  | Security of network services                                                   | No issues, limited  | Limited  | <div><div></div></div> 100% |
| A.8.24  | Use of cryptography<br>Issues on: AWS production                               | Partially effective | Strong   | <div><div></div></div> 85%  |
| A.8.25  | Secure development life cycle<br>Issues on: GitHub organisation                | Not effective       | Strong   | <div><div></div></div> 36%  |
| A.8.28  | Secure coding                                                                  | Effective           | Strong   | <div><div></div></div> 100% |
| A.8.32  | Change management                                                              | Effective           | Strong   | <div><div></div></div> 100% |

Evidence: Strong evidence, Limited evidence, Indirect evidence (see above). "No issues, limited" = No issues found (limited evidence).

# Priorities

## Top risks

- CRITICAL** No access keys for the root account
- CRITICAL** Root account protected with MFA
- CRITICAL** MFA enforced for all users
- HIGH** Between 2 and 4 Global Administrators
- HIGH** Device code flow blocked
- HIGH** Least-privilege base permissions
- HIGH** Microsoft Defender for Cloud plans enabled
- HIGH** No admin ports open to the internet
- HIGH** No open critical or high Security Hub findings
- HIGH** No open critical/high Dependabot alerts

## Quick wins (low effort, meaningful impact)

- CRITICAL** No access keys for the root account
- CRITICAL** Root account protected with MFA
- HIGH** Between 2 and 4 Global Administrators
- HIGH** Device code flow blocked
- HIGH** Microsoft Defender for Cloud plans enabled
- HIGH** Read-only default workflow token

 AWS production | A.8.2

 AWS production | A.8.5

 Noordkust Microsoft 365 | A.8.5

 Noordkust Microsoft 365 | A.8.2

 Noordkust Microsoft 365 | A.8.5

 GitHub organisation | A.8.4

 Noordkust Azure | A.8.16

 AWS production | A.8.20

 AWS production | A.8.8

 GitHub organisation | A.8.8

 AWS production | A.8.2

 AWS production | A.8.5

 Noordkust Microsoft 365 | A.8.2

 Noordkust Microsoft 365 | A.8.5

 Noordkust Azure | A.8.16

 GitHub organisation | A.8.25

# Detailed findings

CRITICAL

FAIL

## No access keys for the root account

 **AWS production** AWS account 111122223333

Amazon Web Services | ISO 27001: A.8.2 Privileged access rights, A.5.17 Authentication information | AWS CIS 1.4

Programmatic access keys for the root user cannot be scoped down and are a high-value target.

**Result:** Root account has active access keys.

### Affected resources (1)

- root (access key 1 last used 2026-06-02)

#### Recommendation (effort: low)

Delete all root access keys and use IAM roles with least privilege for automation.

CRITICAL

FAIL

## Root account protected with MFA

 **AWS production** AWS account 111122223333

Amazon Web Services | ISO 27001: A.8.5 Secure authentication, A.8.2 Privileged access rights | AWS CIS 1.5, 1.6, 1.7 | NIS2 Art. 21(2)(j)

The AWS account root user has unrestricted access. It must be protected with multi-factor authentication (preferably a hardware key) and not be used for daily work. Accounts managed with centralised root access (no root password and no root access keys) pass.

**Result:** Root account does not have MFA enabled.

### Affected resources (1)

- root (root password last used 2026-08-19)

#### Recommendation (effort: low)

Sign in as root, open Security credentials and assign a hardware MFA device (FIDO2 security key recommended). Stop using the root user for daily tasks, store the recovery procedure in a break-glass process, or remove root credentials with AWS Organizations centralised root access.

CRITICAL

WARNING

## MFA enforced for all users

 **Noordkust Microsoft 365** Tenant Noordkust Logistics NV (0f1e2d3c-4b5a-4968-8776-655443322110)

Microsoft 365 / Entra ID | ISO 27001: A.8.5 Secure authentication, A.5.17 Authentication information | M365 CIS v4.0 5.2.2.2 | NIS2 Art. 21(2)(j)

Security Defaults or an enabled Conditional Access policy must require MFA for all users on all cloud apps, without narrowing conditions (locations, platforms, risk) and with exclusions limited to at most 2 break-glass accounts.

**Result:** MFA is enforced for all users and all cloud apps by 'CA001 - Require MFA - all users', but it excludes 3 user(s), 1 group(s): more than break-glass accounts. Review the exclusions.

### Affected resources (5)

- CA001 - Require MFA - all users (enabled)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_ConditionalAccess/PolicyBlade/policyId/340702a6-3407-42a6-8407-02a6340702a6](https://entra.microsoft.com/#view/Microsoft_AAD_ConditionalAccess/PolicyBlade/policyId/340702a6-3407-42a6-8407-02a6340702a6)
- breakglass01@noordkust.example (excluded)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade/~/\\_/overview/userId/e3b1f2ad-e3b1-42ad-83b1-f2ade3b1f2ad](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade/~/_/overview/userId/e3b1f2ad-e3b1-42ad-83b1-f2ade3b1f2ad)
- breakglass02@noordkust.example (excluded)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade/~/\\_/overview/userId/e98aced8-e98a-4ed8-898a-ced8e98aced8](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade/~/_/overview/userId/e98aced8-e98a-4ed8-898a-ced8e98aced8)
- scanner.magazijn@noordkust.example (excluded)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade/~/\\_/overview/userId/98bd54fc-98bd-44fc-88bd-54fc98bd54fc](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade/~/_/overview/userId/98bd54fc-98bd-44fc-88bd-54fc98bd54fc)

- SG-Chauffeurs-NoMFA (excluded (group))  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_IAM/GroupDetailsMenuBlade/~/\\_/Overview/groupId/2f04ff13-2f04-4f13-8f04-ff132f04ff13](https://entra.microsoft.com/#view/Microsoft_AAD_IAM/GroupDetailsMenuBlade/~/_/Overview/groupId/2f04ff13-2f04-4f13-8f04-ff132f04ff13)

#### Recommendation (effort: medium)

Enable a Conditional Access policy "Require MFA for all users" (all cloud apps, exclude only emergency access accounts), or turn on Security Defaults for tenants without Entra ID P1.

HIGH FAIL

## Between 2 and 4 Global Administrators

 **Noordkust Microsoft 365** Tenant Noordkust Logistics NV (0f1e2d3c-4b5a-4968-8776-655443322110)

Microsoft 365 / Entra ID | ISO 27001: A.8.2 Privileged access rights, A.5.18 Access rights | M365 CIS v4.0 1.1.3

Too many Global Administrators increase exposure; fewer than two risks lock-out. Counts enabled active and PIM-eligible holders, including members of role-assignable groups.

**Result:** 6 Global Administrator(s) (1 PIM-eligible), recommended 2-4.

#### Affected resources (6)

- admin.pieters@noordkust.example (active)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade/~/\\_/overview/userId/7ff4b59c-7ff4-459c-8ff4-b59c7ff4b59c](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade/~/_/overview/userId/7ff4b59c-7ff4-459c-8ff4-b59c7ff4b59c)
- k.janssens@noordkust.example (active)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade/~/\\_/overview/userId/c4ffbdab-c4ff-4dab-84ff-bdabc4ffbdab](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade/~/_/overview/userId/c4ffbdab-c4ff-4dab-84ff-bdabc4ffbdab)
- it-support@noordkust.example (active, via group SG-Tier0-Admins)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade/~/\\_/overview/userId/c9cd1238-c9cd-4238-89cd-1238c9cd1238](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade/~/_/overview/userId/c9cd1238-c9cd-4238-89cd-1238c9cd1238)
- l.maes@noordkust.example (eligible (PIM))  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade/~/\\_/overview/userId/c8a8fe9b-c8a8-4e9b-88a8-fe9bc8a8fe9b](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade/~/_/overview/userId/c8a8fe9b-c8a8-4e9b-88a8-fe9bc8a8fe9b)
- breakglass01@noordkust.example (active)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade/~/\\_/overview/userId/e3b1f2ad-e3b1-42ad-83b1-f2ade3b1f2ad](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade/~/_/overview/userId/e3b1f2ad-e3b1-42ad-83b1-f2ade3b1f2ad)
- msp-partner@noordkust.example (active, guest of the managed service provider)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade/~/\\_/overview/userId/b1611880-b161-4880-8161-1880b1611880](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade/~/_/overview/userId/b1611880-b161-4880-8161-1880b1611880)

#### Recommendation (effort: low)

Reduce Global Administrators to 2-4 (including emergency access accounts) and delegate least-privileged roles instead.

HIGH FAIL

## Device code flow blocked

 **Noordkust Microsoft 365** Tenant Noordkust Logistics NV (0f1e2d3c-4b5a-4968-8776-655443322110)

Microsoft 365 / Entra ID | ISO 27001: A.8.5 Secure authentication | M365 CIS v4.0 5.2.2.12

The device code flow is abused in device code phishing to obtain tokens for a victim. An enabled Conditional Access policy should block it (authentication flows condition) for all users and all cloud apps.

**Result:** Device code flow is not blocked by Conditional Access: attackers can use device code phishing to obtain tokens.

#### Recommendation (effort: low)

Create a Conditional Access policy for all users and all cloud apps with the condition Authentication flows > Device code flow and grant Block access; exclude only break-glass accounts and, if needed, a group of meeting-room devices.

HIGH FAIL

## Least-privilege base permissions

 **GitHub organisation** [github.com/noordkust-demo](https://github.com/noordkust-demo)

GitHub | ISO 27001: A.8.4 Access to source code, A.5.15 Access control | GitHub CIS 1.3.8

Base permission write/admin gives every member write access to every repository.

**Result:** Base permission is "write" for all members.

### Affected resources (1)

- Member privileges (base permission write)  
[https://github.com/organizations/noordkust-demo/settings/member\\_privileges](https://github.com/organizations/noordkust-demo/settings/member_privileges)

### Recommendation (effort: medium)

Set base permissions to "Read" or "No permission" and grant write access through teams.

HIGH FAIL

## Microsoft Defender for Cloud plans enabled

 **Noordkust Azure** Tenant 0f1e2d3c-4b5a-4968-8776-655443322110; subscriptions: noordkust-prod, noordkust-dev  
Microsoft Azure | ISO 27001: A.8.16 Monitoring activities | Azure CIS v3.0 2.1.1-2.1.13

Defender plans provide threat detection and vulnerability assessment. Resource Manager and Defender CSPM are expected on every subscription; Servers, Storage, Key Vault, SQL, App Service, Containers, open-source relational databases and Cosmos DB plans are expected when such resources are deployed.

**Result:** 1 subscription(s) have none of the Defender plans their workloads need.

### Affected resources (2)

- noordkust-prod (not enabled: Arm, CloudPosture, VirtualMachines, StorageAccounts, KeyVaults, SqlServers (required: Arm, CloudPosture, VirtualMachines, StorageAccounts, KeyVaults, SqlServers))  
<https://portal.azure.com/#@/resource/subscriptions/e147562e-e147-462e-8147-562ee147562e>
- noordkust-dev (not enabled: CloudPosture, AppServices (required: Arm, CloudPosture, StorageAccounts, AppServices))  
<https://portal.azure.com/#@/resource/subscriptions/e84160a6-e841-40a6-8841-60a6e84160a6>

### Recommendation (effort: low)

Enable the Defender plans matching deployed workloads (Defender for Cloud > Environment settings > subscription > Defender plans), plus Resource Manager and Defender CSPM.

HIGH FAIL

## No admin ports open to the internet

 **AWS production** AWS account 111122223333

Amazon Web Services | ISO 27001: A.8.20 Networks security | AWS CIS 5.2, 5.3 | NIS2 Art. 21(2)(e)

Security groups allowing SSH, RDP or database ports from 0.0.0.0/0, ::/0 or other very broad ranges (IPv4 /8 or wider, IPv6 /16 or wider) are a common initial access vector.

**Result:** 3 security group(s) expose admin/database ports to the internet (0.0.0.0/0, ::/0 or other very broad ranges).

### Affected resources (3)

- tms-windows-app (sg-0a1b2c3d4e5f60718) (ports 3389 from 0.0.0.0/0)  
<https://eu-west-1.console.aws.amazon.com/ec2/home?region=eu-west-1#SecurityGroup:groupId=sg-0a1b2c3d4e5f60718>
- bastion-legacy (sg-0b2c3d4e5f6071829) (ports 22 from 0.0.0.0/0, ::/0)  
<https://eu-west-1.console.aws.amazon.com/ec2/home?region=eu-west-1#SecurityGroup:groupId=sg-0b2c3d4e5f6071829>
- reporting-db (sg-0c3d4e5f607182930) (ports 5432 from 0.0.0.0/0)  
<https://eu-west-1.console.aws.amazon.com/ec2/home?region=eu-west-1#SecurityGroup:groupId=sg-0c3d4e5f607182930>

### Recommendation (effort: medium)

Restrict ingress to known IP ranges, or remove it and use SSM Session Manager or a VPN / zero-trust access instead.

HIGH FAIL

## No open critical or high Security Hub findings

 **AWS production** AWS account 111122223333

Amazon Web Services | ISO 27001: A.8.8 Management of technical vulnerabilities, A.8.9 Configuration management | NIS2 Art. 21(2)(e)

Active, failed critical and high severity Security Hub controls show known misconfigurations that have not been remediated or suppressed.

**Result:** 23 active critical/high failed findings across 4 control(s) (3 critical).

### Affected resources (4)

- S3.8: S3 general purpose buckets should block public access (2 failed finding(s) (2 critical, 0 high) on 2 resource(s))  
<https://eu-west-1.console.aws.amazon.com/securityhub/home?region=eu-west-1#/summary>
- EC2.19: Security groups should not allow unrestricted access to high-risk ports (3 failed finding(s) (1 critical, 2 high) on 3 resource(s))  
<https://eu-west-1.console.aws.amazon.com/securityhub/home?region=eu-west-1#/summary>
- EC2.8: EC2 instances should use IMDSv2 (5 failed finding(s) (0 critical, 5 high) on 5 resource(s))  
<https://eu-west-1.console.aws.amazon.com/securityhub/home?region=eu-west-1#/summary>
- IAM.6: Hardware MFA should be enabled for the root user (1 failed finding(s) (0 critical, 1 high) on 1 resource(s))  
<https://eu-west-1.console.aws.amazon.com/securityhub/home?region=eu-west-1#/summary>

### Recommendation (effort: medium)

Work through the listed controls, fix the affected resources, and suppress findings only with a documented risk acceptance.

HIGH FAIL

## No open critical/high Dependabot alerts

 **GitHub organisation** [github.com/noordkust-demo](https://github.com/noordkust-demo)

GitHub | ISO 27001: A.8.8 Management of technical vulnerabilities, A.5.21 Managing information security in the ICT supply chain, A.8.25 Secure development life cycle | GitHub CIS 1.5.5 | NIS2 Art. 21(2)(e)

Dependabot alerts must be enabled on every repository, and open alerts of critical or high severity indicate unpatched known vulnerabilities. Not enabled on any repository fails; partial coverage warns. Repositories with alerts but without Dependabot security updates (automatic fix pull requests) are also reported.

**Result:** 11 open critical/high Dependabot alerts across 3 repositories. Dependabot security updates not enabled on 2 repositories with alerts on.

### Affected resources (5)

- noordkust-demo/driver-app (4 critical, 3 high)  
<https://github.com/noordkust-demo/driver-app/security/dependabot>
- noordkust-demo/route-planner (0 critical, 3 high)  
<https://github.com/noordkust-demo/route-planner/security/dependabot>
- noordkust-demo/website (0 critical, 1 high)  
<https://github.com/noordkust-demo/website/security/dependabot>
- noordkust-demo/edi-connector (Dependabot security updates not enabled)  
[https://github.com/noordkust-demo/edi-connector/settings/security\\_analysis](https://github.com/noordkust-demo/edi-connector/settings/security_analysis)
- noordkust-demo/driver-app (Dependabot security updates not enabled)  
[https://github.com/noordkust-demo/driver-app/settings/security\\_analysis](https://github.com/noordkust-demo/driver-app/settings/security_analysis)

### Recommendation (effort: medium)

Enable Dependabot alerts and security updates on all repositories (organisation code security configuration), triage and fix open critical and high alerts; set an SLA for remediation.

HIGH FAIL

## Read-only default workflow token

 **GitHub organisation** [github.com/noordkust-demo](https://github.com/noordkust-demo)

GitHub | ISO 27001: A.8.25 Secure development life cycle, A.8.2 Privileged access rights

A default GITHUB\_TOKEN with write permissions amplifies the impact of a compromised workflow.

**Result:** Default GITHUB\_TOKEN has read/write permissions.

### Affected resources (1)

- Workflow permissions (default\_workflow\_permissions: write)  
<https://github.com/organizations/noordkust-demo/settings/actions>

### Recommendation (effort: low)

Set default workflow permissions to "Read repository contents" and disallow Actions from approving pull requests.

HIGH WARNING

## Phishing-resistant MFA for administrators

 **Noordkust Microsoft 365** Tenant Noordkust Logistics NV (0f1e2d3c-4b5a-4968-8776-655443322110)

Microsoft 365 / Entra ID | ISO 27001: A.8.5 Secure authentication, A.8.2 Privileged access rights | M365 CIS v4.0 5.2.2.1, 5.2.2.5

The 14 CIS administrative roles (Global, Privileged Role, Security, Exchange, SharePoint, Conditional Access, Helpdesk, Billing, User, Authentication, Privileged Authentication, Application, Cloud Application and Intune Administrator) should be covered by enforced Conditional Access requiring a phishing-resistant authentication strength (built-in or custom with only FIDO2, Windows Hello for Business or certificate-based MFA).

**Result:** All administrator roles require MFA, but 14 role(s) are not held to a phishing-resistant authentication strength: Global Administrator, Privileged Role Administrator, Security Administrator, Exchange Administrator and 10 more.

### Affected resources (3)

- CA001 - Require MFA - all users (enabled)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_ConditionalAccess/PolicyBlade/policyId/340702a6-3407-42a6-8407-02a6340702a6](https://entra.microsoft.com/#view/Microsoft_AAD_ConditionalAccess/PolicyBlade/policyId/340702a6-3407-42a6-8407-02a6340702a6)
- Global Administrator (MFA without phishing-resistant strength)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_IAM/RoleMenuBlade/~RoleMembers/objectId/4310f435-4310-4435-8310-f4354310f435](https://entra.microsoft.com/#view/Microsoft_AAD_IAM/RoleMenuBlade/~RoleMembers/objectId/4310f435-4310-4435-8310-f4354310f435)
- Privileged Role Administrator (MFA without phishing-resistant strength)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_IAM/RoleMenuBlade/~RoleMembers/objectId/c7c23dcf-c7c2-4dcf-87c2-3dcfc7c23dcf](https://entra.microsoft.com/#view/Microsoft_AAD_IAM/RoleMenuBlade/~RoleMembers/objectId/c7c23dcf-c7c2-4dcf-87c2-3dcfc7c23dcf)

### Recommendation (effort: medium)

Create a Conditional Access policy targeting directory roles that requires the "Phishing-resistant MFA" authentication strength. Tenants without Entra ID P1 should at least turn on Security Defaults.

MEDIUM FAIL

## Access keys rotated within 90 days

 **AWS production** AWS account 111122223333

Amazon Web Services | ISO 27001: A.5.17 Authentication information | AWS CIS 1.14

Long-lived access keys increase the window of opportunity when leaked (e.g. in source code).

**Result:** 3 active access key(s) older than 90 days.

### Affected resources (3)

- ci-deploy (key 1 rotated 2024-03-11)  
<https://us-east-1.console.aws.amazon.com/iam/home#/users/details/ci-deploy>
- backup-sync (key 1 rotated 2023-11-02)  
<https://us-east-1.console.aws.amazon.com/iam/home#/users/details/backup-sync>
- tms-integration (key 2 rotated 2025-01-20)  
<https://us-east-1.console.aws.amazon.com/iam/home#/users/details/tms-integration>

### Recommendation (effort: medium)

Rotate or remove access keys older than 90 days. Prefer IAM roles and short-lived credentials (OIDC federation for CI/CD).

MEDIUM

FAIL

## AWS Config recording enabled

 **AWS production** AWS account 111122223333

Amazon Web Services | ISO 27001: A.8.9 Configuration management | AWS CIS 3.3

AWS Config records configuration changes, which supports asset inventory, change tracking and investigations. Recorders must record all supported resource types, global resources in one region, and have a delivery channel.

**Result:** AWS Config is not recording in any of the 4 evaluated regions.

### Affected resources (4)

- eu-west-1 (not recording)  
<https://eu-west-1.console.aws.amazon.com/config/home?region=eu-west-1#/dashboard>
- eu-central-1 (not recording)  
<https://eu-central-1.console.aws.amazon.com/config/home?region=eu-central-1#/dashboard>
- us-east-1 (not recording)  
<https://us-east-1.console.aws.amazon.com/config/home?region=us-east-1#/dashboard>
- eu-west-3 (not recording)  
<https://eu-west-3.console.aws.amazon.com/config/home?region=eu-west-3#/dashboard>

### Recommendation (effort: low)

Enable AWS Config recorders for all supported resource types in all used regions, with global resource recording in one region and a delivery channel to S3.

MEDIUM

FAIL

## EC2 instances require IMDSv2

 **AWS production** AWS account 111122223333

Amazon Web Services | ISO 27001: A.8.9 Configuration management | AWS CIS 5.6

IMDSv1 is susceptible to SSRF-based credential theft. IMDSv2 requires session tokens.

**Result:** 5 of 9 instances allow IMDSv1.

### Affected resources (5)

- tms-app-01 (i-0a12b34c56d78e901, IMDSv1 allowed)  
<https://eu-west-1.console.aws.amazon.com/ec2/home?region=eu-west-1#InstanceDetails:instanceId=i-0a12b34c56d78e901>
- tms-app-02 (i-0b23c45d67e89f012, IMDSv1 allowed)  
<https://eu-west-1.console.aws.amazon.com/ec2/home?region=eu-west-1#InstanceDetails:instanceId=i-0b23c45d67e89f012>
- sftp-gateway (i-0c34d56e78f90a123, IMDSv1 allowed)  
<https://eu-west-1.console.aws.amazon.com/ec2/home?region=eu-west-1#InstanceDetails:instanceId=i-0c34d56e78f90a123>
- reporting-worker (i-0d45e67f89a01b234, IMDSv1 allowed)  
<https://eu-west-1.console.aws.amazon.com/ec2/home?region=eu-west-1#InstanceDetails:instanceId=i-0d45e67f89a01b234>
- bastion-legacy (i-0e56f78a90b12c345, IMDSv1 allowed)  
<https://eu-west-1.console.aws.amazon.com/ec2/home?region=eu-west-1#InstanceDetails:instanceId=i-0e56f78a90b12c345>

### Recommendation (effort: medium)

Set HttpTokens=required on instances and launch templates; set the account default to IMDSv2.

MEDIUM

FAIL

## Limited organisation owners

 **GitHub organisation** [github.com/noordkust-demo](https://github.com/noordkust-demo)

GitHub | ISO 27001: A.8.2 Privileged access rights | GitHub CIS 1.3.3

Organisation owners have full control. Keep the number small, but have at least two to avoid lock-out.

**Result:** 7 organisation owners.

### Affected resources (7)

- pieters-nk (organisation owner)  
<https://github.com/pieters-nk>
- kjanssens (organisation owner)  
<https://github.com/kjanssens>
- devops-bot (organisation owner)  
<https://github.com/devops-bot>
- lmaes (organisation owner)  
<https://github.com/lmaes>

- rvdv (organisation owner)  
<https://github.com/rvdv>
- msp-dev (organisation owner)  
<https://github.com/msp-dev>
- ci-admin (organisation owner)  
<https://github.com/ci-admin>

#### Recommendation (effort: low)

Reduce owners to 2-4 people and use the security manager or custom roles for delegated duties.

MEDIUM

FAIL

## Privileged accounts are cloud-only

 **Noordkust Microsoft 365** Tenant Noordkust Logistics NV (0f1e2d3c-4b5a-4968-8776-655443322110)  
Microsoft 365 / Entra ID | ISO 27001: A.8.2 Privileged access rights | M365 CIS v4.0 1.1.1

Synchronised on-premises accounts in privileged roles (active or PIM-eligible, directly or through role-assignable groups) allow an AD compromise to pivot to the cloud tenant.

**Result:** 2 privileged account(s) are synchronised from on-premises AD.

#### Affected resources (2)

- k.janssens@noordkust.example (Global Administrator, synchronised from on-premises (active))  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade~/overview/userId/c4ffb4dab-c4ff-4dab-84ff-bdabc4ffbdab](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade~/overview/userId/c4ffb4dab-c4ff-4dab-84ff-bdabc4ffbdab)
- l.maes@noordkust.example (Exchange Administrator, synchronised from on-premises (eligible))  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade~/overview/userId/c8a8fe9b-c8a8-4e9b-88a8-fe9bc8a8fe9b](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade~/overview/userId/c8a8fe9b-c8a8-4e9b-88a8-fe9bc8a8fe9b)

#### Recommendation (effort: medium)

Use dedicated cloud-only accounts for Entra ID administrative roles.

MEDIUM

FAIL

## S3 buckets deny plain HTTP

 **AWS production** AWS account 111122223333  
Amazon Web Services | ISO 27001: A.8.24 Use of cryptography | AWS CIS 2.1.1 | NIS2 Art. 21(2)(h)

A bucket policy that denies requests where aws:SecureTransport is false ensures data is only transferred over TLS.

**Result:** 9 of 14 evaluated buckets do not deny plain HTTP requests (aws:SecureTransport).

#### Affected resources (4)

- noordkust-invoices-archive (no bucket policy)  
<https://s3.console.aws.amazon.com/s3/buckets/noordkust-invoices-archive?region=eu-west-1>
- nk-tms-exports (no bucket policy)  
<https://s3.console.aws.amazon.com/s3/buckets/nk-tms-exports?region=eu-west-1>
- nk-edi-inbound (policy does not deny aws:SecureTransport=false)  
<https://s3.console.aws.amazon.com/s3/buckets/nk-edi-inbound?region=eu-west-1>
- nk-backup-sync (no bucket policy)  
<https://s3.console.aws.amazon.com/s3/buckets/nk-backup-sync?region=eu-west-1>

#### Recommendation (effort: low)

Add a Deny statement for s3:\* on the bucket and its objects with the condition Bool aws:SecureTransport = false to every bucket policy.

MEDIUM

WARNING

## Backup vaults protected against deletion

 **Noordkust Azure** Tenant 0f1e2d3c-4b5a-4968-8776-655443322110; subscriptions: noordkust-prod, noordkust-dev  
Microsoft Azure | ISO 27001: A.8.13 Information backup

Recovery Services and Backup vaults should keep soft delete enabled and use immutability so an attacker with access cannot delete or alter backups.

**Result:** 2 of 2 backup vault(s) do not have immutability enabled.

#### Affected resources (2)

- rsv-nk-prod (immutability off)

<https://portal.azure.com/#@/resource/subscriptions/e147562e-e147-462e-8147-562ee147562e/resourceGroups/rg-backup/providers/Microsoft.RecoveryServices/vaults/rsv-nk-prod>  
- bv-nk-blobs (immutability off)  
<https://portal.azure.com/#@/resource/subscriptions/e147562e-e147-462e-8147-562ee147562e/resourceGroups/rg-backup/providers/Microsoft.DataProtection/backupVaults/bv-nk-blobs>

#### Recommendation (effort: low)

Enable soft delete (preferably always-on) and immutability (lock it once validated) on every Recovery Services and Backup vault.

MEDIUM

WARNING

## Privileged Identity Management in use

 **Noordkust Microsoft 365** Tenant Noordkust Logistics NV (0f1e2d3c-4b5a-4968-8776-655443322110)  
Microsoft 365 / Entra ID | ISO 27001: A.8.2 Privileged access rights | M365 CIS v4.0 5.3.1

Just-in-time role activation reduces standing privileged access. Compares permanent active assignments of privileged roles with PIM-eligible assignments; more than 2 permanent Global Administrators (break-glass) fail.

**Result:** No PIM-eligible assignments for privileged roles: privileged roles are permanently assigned.

#### Affected resources (3)

- admin.pieters@noordkust.example (permanent Global Administrator)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade~/overview/userId/7ff4b59c-7ff4-459c-8ff4-b59c7ff4b59c](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade~/overview/userId/7ff4b59c-7ff4-459c-8ff4-b59c7ff4b59c)
- k.janssens@noordkust.example (permanent Global Administrator)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade~/overview/userId/c4ffbdab-c4ff-4dab-84ff-bdabc4ffbdab](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade~/overview/userId/c4ffbdab-c4ff-4dab-84ff-bdabc4ffbdab)
- it-support@noordkust.example (permanent Helpdesk Administrator)  
[https://entra.microsoft.com/#view/Microsoft\\_AAD\\_UsersAndTenants/UserProfileMenuBlade~/overview/userId/c9cd1238-c9cd-4238-89cd-1238c9cd1238](https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/UserProfileMenuBlade~/overview/userId/c9cd1238-c9cd-4238-89cd-1238c9cd1238)

#### Recommendation (effort: medium)

Convert permanent privileged role assignments into PIM eligible assignments with approval and MFA on activation.

LOW

WARNING

## Guest directory access restricted

 **Noordkust Microsoft 365** Tenant Noordkust Logistics NV (0f1e2d3c-4b5a-4968-8776-655443322110)  
Microsoft 365 / Entra ID | ISO 27001: A.8.3 Information access restriction | M365 CIS v4.0 5.1.6.2

Guests should not be able to enumerate the full directory.

**Result:** Guests have limited access to directory objects (default); consider the most restrictive setting.

#### Recommendation (effort: low)

Set guest user access to "Guest user access is restricted to properties and memberships of their own directory objects".

LOW

WARNING

## Users cannot register applications

 **Noordkust Microsoft 365** Tenant Noordkust Logistics NV (0f1e2d3c-4b5a-4968-8776-655443322110)  
Microsoft 365 / Entra ID | ISO 27001: A.5.15 Access control, A.8.9 Configuration management | M365 CIS v4.0 5.1.2.2

Default users being able to create app registrations increases shadow IT and persistence options.

**Result:** All users can register applications.

#### Recommendation (effort: low)

Set "Users can register applications" to No and assign Application Developer to those who need it.

---

LOW

WARNING

RISK ACCEPTED

## Weak MFA methods (SMS / voice) disabled

 **Noordkust Microsoft 365** Tenant Noordkust Logistics NV (0f1e2d3c-4b5a-4968-8776-655443322110)

Microsoft 365 / Entra ID | ISO 27001: A.8.5 Secure authentication | M365 CIS v4.0 5.2.3.5

SMS and voice calls are vulnerable to SIM swapping and interception. Until the authentication methods policy migration is complete, the legacy MFA and SSPR policies can still allow them.

**Result:** Weak methods enabled: Sms, Voice.

### Affected resources (2)

- Sms
- Voice

#### Recommendation (effort: low)

Disable SMS and voice call in the Authentication methods policy after migrating users to Microsoft Authenticator or passkeys.

Triage note: SMS stays enabled for warehouse staff without company smartphones until Q2 2027. Compensating control: sign-in restricted to the warehouse network via Conditional Access.

---

INFO

WARNING

## Public repositories reviewed

 **GitHub organisation** [github.com/noordkust-demo](https://github.com/noordkust-demo)

GitHub | ISO 27001: A.8.12 Data leakage prevention

Lists public repositories so the owners can confirm each is intentionally public.

**Result:** 2 public repositories: confirm they are intended to be public.

### Affected resources (2)

- noordkust-demo/website (public)  
<https://github.com/noordkust-demo/website>
- noordkust-demo/tms-api-client (public, contains internal hostnames in README)  
<https://github.com/noordkust-demo/tms-api-client>

#### Recommendation (effort: low)

Confirm each public repository is intended to be public; archive or make private otherwise.

# Scope, method and limitations

## Systems in scope

-  Noordkust Microsoft 365 - Microsoft 365 / Entra ID - Tenant Noordkust Logistics NV (0f1e2d3c-4b5a-4968-8776-655443322110)
-  Noordkust Azure - Microsoft Azure - Tenant 0f1e2d3c-4b5a-4968-8776-655443322110; subscriptions: noordkust-prod, noordkust-dev
-  AWS production - Amazon Web Services - AWS account 111122223333
-  GitHub organisation - GitHub - github.com/noordkust-demo

## Method

The assessment was performed between 04 October 2026 and 04 October 2026 using read-only API access (Microsoft Graph, Azure Resource Manager, AWS APIs and the GitHub REST API). No changes were made to the environments. This is a best-practice and compliance baseline: every automated check for the platforms in scope was run. Scores are weighted by the severity of each check. Findings marked not applicable or false positive are left out of the score.

## Limitations

This is a point-in-time, automated configuration review. It does not include penetration testing, review of on-premises systems, endpoint configuration, or organisational controls (policies, processes, awareness). Results depend on the permissions and licences available to the scanning identity; checks that could not be evaluated are listed below. A passed check is not a guarantee of security.

## Access revocation

Credentials handling for this scan: secrets were deleted automatically when the scan finished. We recommend removing the scanner access (IAM role, app consent / registration, Azure role assignments, GitHub token) once it is no longer needed.

## Annex A controls not covered by automated checks

These technologically assessable controls had no automated result in this scan. They need to be assessed by other means (interview, document review or additional checks).

- A.5.9** Inventory of information and other associated assets
- A.5.28** Collection of evidence
- A.5.33** Protection of records
- A.8.6** Capacity management
- A.8.7** Protection against malware
- A.8.10** Information deletion
- A.8.11** Data masking
- A.8.14** Redundancy of information processing facilities
- A.8.22** Segregation of networks
- A.8.23** Web filtering
- A.8.26** Application security requirements
- A.8.27** Secure system architecture and engineering principles

## Passed checks

- PASS** No open secret scanning alerts (GitHub organisation, A.8.28)
- PASS** No publicly accessible S3 buckets (AWS production, A.8.3)
- PASS** Organisation requires 2FA (GitHub organisation, A.8.5)
- PASS** Account-level S3 Block Public Access (AWS production, A.8.3)
- PASS** Console IAM users have MFA (AWS production, A.8.5)
- PASS** Default branches protected (GitHub organisation, A.8.32)
- PASS** GuardDuty threat detection enabled (AWS production, A.8.16)

**PASS** Legacy authentication blocked (Noordkust Microsoft 365, A.8.5)  
**PASS** Multi-region CloudTrail with log validation (AWS production, A.8.15)  
**PASS** No guests or service principals in privileged roles (Noordkust Microsoft 365, A.8.2)  
**PASS** No IAM users with administrator access (AWS production, A.8.2)  
**PASS** No long-lived application secrets (Noordkust Microsoft 365, A.5.17)  
**PASS** No management or database ports open to the internet (Noordkust Azure, A.8.20)  
**PASS** No members without 2FA (GitHub organisation, A.8.5)  
**PASS** No over-privileged application permissions (Noordkust Microsoft 365, A.8.2)  
**PASS** No public snapshots or AMIs (AWS production, A.8.3)  
**PASS** No publicly accessible RDS instances (AWS production, A.8.20)  
**PASS** No unhealthy high-severity Defender recommendations (Noordkust Azure, A.8.8)  
**PASS** Secret scanning enabled (GitHub organisation, A.8.28)  
**PASS** SQL auditing, TDE and Entra admin (Noordkust Azure, A.8.15)  
**PASS** SQL servers not open to the internet (Noordkust Azure, A.8.20)  
**PASS** Storage accounts disallow public blob access (Noordkust Azure, A.8.3)  
**PASS** Storage network access restricted (Noordkust Azure, A.8.20)  
**PASS** Users registered for MFA (Noordkust Microsoft 365, A.8.5)  
**PASS** Access requires managed or compliant devices (Noordkust Microsoft 365, A.8.1)  
**PASS** Activity log exported (Noordkust Azure, A.8.15)  
**PASS** Amazon Inspector vulnerability scanning (AWS production, A.8.8)  
**PASS** Authenticator number matching and context (Noordkust Microsoft 365, A.8.5)  
**PASS** AWS Backup plans protect resources (AWS production, A.8.13)  
**PASS** Default security groups restrict all traffic (AWS production, A.8.20)  
**PASS** EBS encryption by default (AWS production, A.8.24)  
**PASS** GitHub Actions restricted to trusted actions (GitHub organisation, A.5.21)  
**PASS** GitHub Apps hold least privilege (GitHub organisation, A.5.21)  
**PASS** Guest invitations restricted (Noordkust Microsoft 365, A.5.15)  
**PASS** Key Vault soft delete, purge protection and RBAC (Noordkust Azure, A.8.24)  
**PASS** Limited subscription Owners (Noordkust Azure, A.8.2)  
**PASS** Members cannot create public repositories (GitHub organisation, A.8.12)  
**PASS** No open critical/high code scanning alerts (GitHub organisation, A.8.28)  
**PASS** No stale enabled accounts (90+ days) (Noordkust Microsoft 365, A.5.18)  
**PASS** No unused credentials (45+ days) (AWS production, A.5.18)  
**PASS** Outside collaborators reviewed (GitHub organisation, A.5.19)  
**PASS** RDS automated backups retained 7+ days (AWS production, A.8.13)  
**PASS** RDS storage encrypted (AWS production, A.8.24)  
**PASS** Secret push protection enabled (GitHub organisation, A.8.28)  
**PASS** Security Hub enabled (AWS production, A.8.16)  
**PASS** Session controls for administrators (Noordkust Microsoft 365, A.8.5)  
**PASS** Sign-in and user risk policies (Noordkust Microsoft 365, A.8.5)  
**PASS** SPF, DKIM and DMARC enforced on mail domains (Noordkust Microsoft 365, A.5.14)  
**PASS** Storage enforces HTTPS and TLS 1.2+ (Noordkust Azure, A.8.24)  
**PASS** User consent to applications restricted (Noordkust Microsoft 365, A.5.15)  
**PASS** VPC flow logs enabled (AWS production, A.8.15)  
**PASS** Customer managed KMS keys rotated (AWS production, A.8.24)  
**PASS** Deploy keys are read-only (GitHub organisation, A.5.17)  
**PASS** IAM Access Analyzer enabled (AWS production, A.5.18)  
**PASS** Microsoft Secure Score (Noordkust Microsoft 365, A.8.9)  
**PASS** Private repository forking restricted (GitHub organisation, A.8.12)  
**PASS** Security contact configured (Noordkust Azure, A.5.24)  
**PASS** Security features on by default for new repositories (GitHub organisation, A.8.9)  
**PASS** Strong IAM password policy (AWS production, A.5.17)  
**PASS** Webhooks use verified HTTPS (GitHub organisation, A.8.21)